MODULE 24 · DOMAIN 5 - GOVERNANCE, SAFETY AND RISK MANAGEMENT

Compliance and the Deployment Platform

GDPR, HIPAA and FedRAMP as constraints on architecture, zero data retention and residency, and the five platforms compared.

DOMAIN 5 of 7 EXAM WEIGHT 14% MODULE 24 of 38

admin@sthithapragna.com

Choose the bank vault before choosing what to store in it. **Compliance picks the platform; the platform picks the features.**

Compliance assessment, in order

01
Map data
What data, whose, where it flows.

02
Regimes, roles
Which laws; who is controller or processor.

03
Platform
And organisation that meet them.

04
Eligible features
What that platform allows.

05
Design within
Minimise, retain, log, erase.

06
Document
Record and review the decisions.

ON THE EXAM

Eliminate, then optimise. A design that breaks a regime is not a candidate, however good it is.

GDPR as architecture

PRINCIPLE	DESIGN DECISION
Roles	Customer controls; Anthropic processes under its DPA; on Bedrock, AWS
Minimisation	Send only the fields each step needs
Retention	Set limits for prompts, logs, traces and eval sets
Data-subject rights	Find and erase a person's data in every store you keep
Transfers	Standard contractual clauses, with the UK addendum
EU processing	Bedrock or Google Cloud EU regions; not the first-party API

ON THE EXAM

Your logs, traces and evaluation sets are personal data too. They need retention limits and erasure.

HIPAA as architecture

REQUIREMENT	WHAT IT MEANS FOR THE DESIGN
A signed BAA	The agreement is the source of truth for what is covered
A HIPAA-ready organisation	Enforced per organisation; use a separate one for non-PHI work
Eligible features only	Ineligible features return a 400 error
Excluded today	Batch, Files, Skills, code execution, MCP connector, Managed Agents
No PHI in JSON schemas	Property names, enums and patterns stay generic

ON THE EXAM

Removing names is not de-identification, and a pilot with real records is still processing PHI.

FedRAMP routes to Claude, October 2026

ROUTE	STATUS
Claude for Government	FedRAMP High; desktop app in a dedicated government environment
Amazon Bedrock in AWS GovCloud	FedRAMP High
Google Cloud with Assured Workloads	FedRAMP High
Claude Enterprise and the Claude API	Not FedRAMP authorised today

ON THE EXAM

SOC 2 and ISO certificates are not FedRAMP. A FedRAMP requirement narrows the routes to these three.

The five platforms, October 2026

PLATFORM	OPERATED BY	NOTE FOR AN ARCHITECT
Claude API	Anthropic	Features first; ZDR and HIPAA-ready orgs; US or global
Claude Platform on AWS	Anthropic, via AWS billing	Batch, Skills, Managed Agents; not HIPAA-ready
Amazon Bedrock	AWS	EU regions, GovCloud; no Batch, Skills or MCP connector
Google Cloud	Google	EU regions, Assured Workloads; no Batch or code execution
Microsoft Foundry	Anthropic, on Azure	No Batch or Managed Agents

ON THE EXAM

Constraints pick the row. Then check that the row offers the features the design needs.

Retention and residency, October 2026

CONTROL	WHAT TO KNOW
Zero data retention	Per organisation, via sales; nothing stored at rest after the response
Outside ZDR	Batch, Files, Skills, code execution, MCP connector, Managed Agents, Console
Covered models	Fable and Mythos require 30-day retention
Flagged content	May be kept for up to two years
inference_geo	US or global only; US-only inference costs 1.1x

ON THE EXAM

Using a non-eligible feature does not fail under ZDR. It quietly steps outside the arrangement.

Compliance traps the exam sets

- **Removing names** is not de-identification.
- **A pilot with real data** is still processing that data.
- **Features first, compliance later** means rebuilding.
- **Certificates are not interchangeable:** SOC 2 is not FedRAMP; ZDR is not HIPAA.
- **Logs, traces and eval sets** hold personal data too.

> ON THE EXAM
>
> Each trap offers an attractive shortcut. The constraint applies anyway.

> Valdane Versicherung, a German insurer, wants Claude to summarise claims files. Its data protection officer requires all processing to stay in the EU.
>
> A developer plans to use the first-party Claude API with inference restricted by region.

What should Corvane recommend?

A. Use Bedrock or Google Cloud in an EU region, and confirm the features needed are available there

B. Use the first-party API with inference_geo set to the EU

C. Use the first-party API with global routing, covered by the DPA

D. Use the first-party API with US-only inference, as the closest option

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Use Bedrock or Google Cloud in an EU region, and confirm the features needed are available there

Meets the EU constraint; then check the feature gaps.

B Use the first-party API with inference_geo set to the EU

No EU option exists: only US or global.

C Use the first-party API with global routing, covered by the DPA

A DPA governs processing; it does not keep it in the EU.

D Use the first-party API with US-only inference, as the closest option

Firmly outside the EU.

THE SIGNAL

EU-only processing: an EU region on Bedrock or Google Cloud. Then check feature availability there.

> A Mereside member asks for their personal data to be erased. Agent assist keeps call transcripts in traces and logs, and some calls were copied into the evaluation set.
>
> The CRM team has already deleted the member's record.

What must Corvane's design support?

A Nothing more, since the CRM record is gone

B A request to Anthropic to delete the member's data

C Finding and erasing the member's data in traces, logs and eval sets, or recording a lawful basis to keep it, under defined retention limits

D Nothing, because data processed by AI is exempt from erasure

◆ PAUSE AND DECIDE

What must Corvane's design support?

A Nothing more, since the CRM record is gone

Copies remain in traces, logs and the eval set.

B A request to Anthropic to delete the member's data

The copies are in Mereside's own stores.

C Finding and erasing the member's data in traces, logs and eval sets, or recording a lawful basis to keep it, under defined retention limits

Rights apply to every store the system keeps.

D Nothing, because data processed by AI is exempt from erasure

No such exemption.

THE SIGNAL

Data-subject rights reach every copy: traces, logs, caches and evaluation sets. Design for it up front.

> Quillon wants Claude to run code that analyses tables of lab results. The request runs in its HIPAA-ready organisation.
>
> The API returns a 400 error naming code execution.

What should Corvane recommend?

A Treat it as outside the BAA: do the analysis in Quillon's own code, or with eligible features

B Move the job to Quillon's non-PHI organisation

C Remove patient names from the tables and retry

D Ask Anthropic support to unblock code execution for the organisation

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Treat it as outside the BAA: do the analysis in Quillon's own code, or with eligible features

The error is the control working. Design around it.

B Move the job to Quillon's non-PHI organisation

Moves PHI outside the BAA.

C Remove patient names from the tables and retry

Not de-identification, and the feature is still excluded.

D Ask Anthropic support to unblock code execution for the organisation

The block reflects BAA scope, not a setting to toggle.

THE SIGNAL

A 400 for an ineligible feature is the safeguard working. Stay inside eligible features.

> A Quillon developer builds a structured-output schema for ward handover notes. One enum lists the current patients on the ward by name.
>
> The requests run in Quillon's HIPAA-ready organisation.

What should Corvane recommend?

A Keep it, since the schema travels inside a covered request

B Keep it, but encode the names in the enum

C Send the schema from the non-PHI organisation instead

D Keep PHI out of the schema; use generic fields, with patient details only in the message content

◆ PAUSE AND DECIDE

What should Corvane recommend?

A Keep it, since the schema travels inside a covered request

Schemas are compiled and cached without PHI protections.

B Keep it, but encode the names in the enum

Encoded identifiers are still PHI.

C Send the schema from the non-PHI organisation instead

Same names, now with no coverage at all.

D Keep PHI out of the schema; use generic fields, with patient details only in the message content

Follows Anthropic's PHI guidance exactly.

THE SIGNAL

No PHI in JSON schemas: names, enums, constants and patterns stay generic.

> The Office of Community Grants, a US federal agency, must use FedRAMP High authorised services. It reviews about 40,000 grant applications a year.
>
> It wants an API integration for screening applications, and a chat assistant for staff.

What should Corvane recommend?

A. Claude Enterprise for both, since it holds security and quality certifications

B. Bedrock in AWS GovCloud, or Google Cloud with Assured Workloads, for the API; Claude for Government for staff

C. The Claude API with zero data retention for both

D. Claude Platform on AWS for both

◆ PAUSE AND DECIDE

What should Corvane recommend?

A. Claude Enterprise for both, since it holds security and quality certifications

Not FedRAMP authorised. Other certificates do not substitute.

B. Bedrock in AWS GovCloud, or Google Cloud with Assured Workloads, for the API; Claude for Government for staff

FedRAMP High routes for both needs.

C. The Claude API with zero data retention for both

ZDR is not FedRAMP. The API is not authorised.

D. Claude Platform on AWS for both

Not a FedRAMP High route.

THE SIGNAL

FedRAMP High narrows the choice: GovCloud Bedrock, Assured Workloads, or Claude for Government.

> Tallyhawk wants Managed Agents, Skills and the Batch API for a new back-office workload with no health data.
>
> Its procurement team requires all cloud spend to go through its AWS Marketplace account.

Which platform fits?

A Run it on Amazon Bedrock

B Run it on Google Cloud Agent Platform

C Run it on Microsoft Foundry

D Run it on Claude Platform on AWS

◆ PAUSE AND DECIDE

Which platform fits?

A Run it on Amazon Bedrock

AWS billing, but no Batch endpoint, Skills or Managed Agents.

B Run it on Google Cloud Agent Platform

Not AWS billing, and lacks Batch and Managed Agents.

C Run it on Microsoft Foundry

No Batch or Managed Agents, and not AWS billing.

D Run it on Claude Platform on AWS

Anthropic-operated, AWS-billed, with all three features.

THE SIGNAL

Billing through AWS and Anthropic's newest features: Claude Platform on AWS. Not HIPAA-ready, so fine here.

> Corvane is starting a new Quillon workload that drafts responses to patient billing disputes.
>
> A developer wants to prototype straight away with real disputes in the general-purpose organisation.

What should come first?

A. Map the data and regimes, confirm roles and BAA scope, then choose the organisation and features

B. Prototype with real disputes in the general organisation, then review compliance

C. Choose the features first, then check which are eligible

D. Ask Claude whether the design is HIPAA compliant

◆ PAUSE AND DECIDE

What should come first?

A Map the data and regimes, confirm roles and BAA scope, then choose the organisation and features

Billing disputes hold PHI. The constraint comes first.

B Prototype with real disputes in the general organisation, then review compliance

A prototype on real records is processing PHI without cover.

C Choose the features first, then check which are eligible

Features first means rebuilding.

D Ask Claude whether the design is HIPAA compliant

Not a compliance assessment.

THE SIGNAL

Billing disputes are PHI. Map, then choose the organisation, then the features.

> Harrowgate Legal, a law firm, has a zero data retention arrangement and wants nothing stored at rest.
>
> Its design uploads case documents through the Files API, runs nightly reviews through the Batch API, and calls the Messages API.

Which two changes keep the work inside its ZDR arrangement? Choose two.

A Keep the Files API, since ZDR is set for the organisation

B Send documents inline in Messages requests instead of through the Files API

C Run the nightly reviews as ordinary Messages requests instead of batches

D Test prompts with real case documents in the Console playground

E Move to the Fable tier for better legal reasoning

◆ PAUSE AND DECIDE

Which two changes keep the work inside its ZDR arrangement? Choose two.

A Keep the Files API, since ZDR is set for the organisation

Files is outside ZDR. The API does not block it.

B Send documents inline in Messages requests instead of through the Files API

Messages is covered by ZDR.

C Run the nightly reviews as ordinary Messages requests instead of batches

Batch stores jobs; Messages does not.

D Test prompts with real case documents in the Console playground

The Console is outside ZDR.

E Move to the Fable tier for better legal reasoning

Covered models require 30-day retention.

THE SIGNAL

ZDR covers Messages, not stateful features. Non-eligible features are not blocked; they step outside.

In five lines

- **Compliance picks the platform; the platform picks the features.** Map first.
- **GDPR:** roles, minimisation, retention, erasure everywhere; EU processing via Bedrock or Google.
- **HIPAA:** BAA, HIPAA-ready org, eligible features only, no PHI in schemas.
- **FedRAMP High:** Claude for Government, Bedrock GovCloud, Google Assured Workloads.
- **ZDR covers Messages, not stateful features.** Check the platform table every time.

COMING UP

Next: bias, fairness and transparency, and the 4D lens.